Informe de Inteligencia: Caso Servidor 4Geeks Academy

Autopsia Forense y Plan de Resiliencia Técnica (NIST / ISO 27001)

Analista: Solange Neves Leirós

Objetivo: Debian OS / Entorno Simulado

Estado de la Amenaza: Neutralizada

Resumen Ejecutivo del Incidente

El Activo Comprometido

Servidor Web: Debian (4Geeks)

Servicios Expuestos: FTP, HTTP, SSH

El Vector de Intrusión

Aplicación Web (WordPress)

Causas Raíz:

1. Credenciales débiles expuestas
2. Permisos tóxicos globales (777)

El Impacto y Estado

- Sin **persistencia** detectada en el sistema.
- Técnicas **Anti-Forenses** confirmadas (borrado de logs).
- Estado Actual: **Contenido** y en fase de Hardening estructural.

Línea de Tiempo del Compromiso

Uso Normal

Jul - Sep 2024

Instalación y uso normal. Operaciones nominales del servidor.

Compromiso

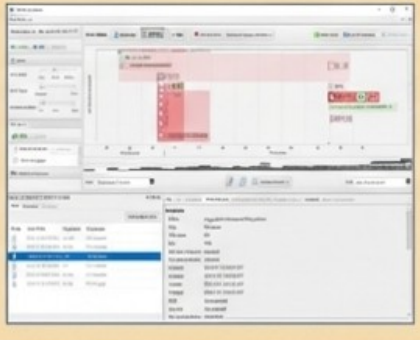
Finales Sep 2024

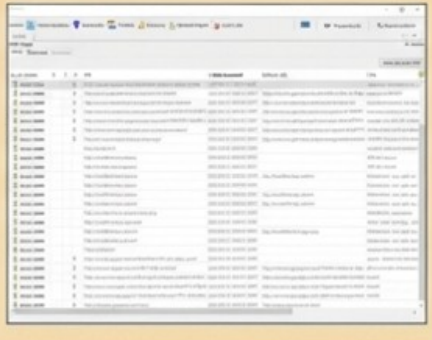
Detección de servicios expuestos. FTP anónimo habilitado y entorno web con chmod 777.

Ocultación

Momento Crítico

Infiltración vía WordPress. Uso de credenciales cacheadas, descarga de herramientas externas (XAMPP) y uso de /srv/ftp.





Post-Incidente

Post-Brecha

Ejecución de técnicas anti-forenses. Borrado del historial del sistema. Abandono del servidor sin persistencia detectada.

Anatomía del Vector de Ataque (Kill Chain)

Entorno Tóxico

`Permisos 777 en /var/www/html`

Cualquier usuario del sistema cuenta con privilegios de lectura, escritura y ejecución.

Exposición Crítica

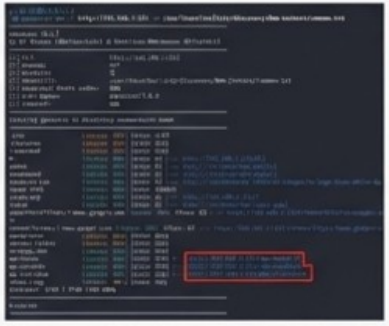
wp-config.php

```
Password: '123456'
```

Exposición directa de credenciales de la base de datos en texto plano.

Toma de Control Web

Directorio expuesto a webshells: `/wp-content/uploads/`



Consolidación

Control total de la aplicación y Base de Datos.

Evidencia Forense I: Artefactos de Intrusión

Directorios de Interés (Fira Code)

```
/home
   /debian
      /.mozilla
         /firefox
```

`[/home/debian/.mozilla/firefox]`

Evidence Card A: Navegación Sospechosa

Búsqueda y descarga de herramientas externas (XAMPP). Múltiples interacciones con CAPTCHAs sugieren preparación para exfiltración o tunelización.

Source Name	S	C	O	URL	Date Accessed	Title
places.sqlite			3	https://www.google.com/search?client=firefox-b-e&q=xampp	2024-09-03 22:31:14 CEST	xampp - Buscar con Google
places.sqlite			2	https://www.apachefriends.org/download.html	2024-09-25 22:21:11 CEST	Download XAMPP
places.sqlite			2	https://www.apachefriends.org/download_success.html	2024-09-03 22:32:27 CEST	XAMPP Download Success
places.sqlite			2	https://inf.ucc.disourceforge.net/projects/xampp/%XAMPP%20Mac%25...	2024-09-03 22:32:31 CEST	Download xampp-osx-8.0.25-0...
places.sqlite			2	https://inf.ucc.disourceforge.net/projects/xampp/%XAMPP%20Mac%25...	2024-09-03 22:32:31 CEST	Download xampp-osx-8.0.25-6...
places.sqlite			2	https://sourceforge.net/projects/xampp/postdownload	2024-09-25 22:32:28 CEST	Find out more about XAMPP

Evidence Card: Reutilización de Credenciales

Explotación de sesiones activas. Acceso directo al login de WordPress y cuentas de Gmail utilizando la infraestructura del propio servidor comprometido.

Name	Location
Log In ‹ my web site - WordPress	http://localhost/wp-login.php
WordPress › Installation	http://localhost/wp-admin/install.php
Google Search	https://www.google.com/search?client=firefox-b-e&q=gmail
Accedi - Account Google	https://accounts.google.com/v3/signin/identifier?continue=...
Gmail: Correo electrónico	https://www.google.com/intl/es-419/gmail/about/

Conclusión del Analista

El atacante utilizó la propia infraestructura del navegador del servidor para orquestar la descarga de herramientas, aprovechando accesos previos.

Evidencia Forense II: Técnicas Anti-Forenses y Persistencia

The Phantom Artifact

```
$ ls -la /var/log/
Total 10
-rw-r----- 1 root adm  113209 Sep 30 10:22 syslog
-rw-r--r-- 1 root root 143256 Sep 30 09:15 dpkg.log
-rw-r----- 1 root adm   98304 Sep 30 10:20 kern.log

-rw-r----- 1 root adm  113209 Sep 30 10:22 syslog
-rw-r--r-- 1 root root 143256 Sep 30 09:15 dpkg.log
-rw-r----- 1 root adm   98304 Sep 30 10:20 kern.log
```

Artefacto Ausente: /var/log/auth.log

El archivo crítico para rastrear accesos SSH remotos fue eliminado intencionalmente. Esto confirma la aplicación de técnicas anti-forenses para borrar el rastro operativo.

Hallazgo Forense: Sin Persistencia

```
$ ps aux

USER       PID XCPU %MEN   VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.1 19324  4096 ?        Ss   Sep30   0:01 /sbin/init
root         2  0.0  0.0     0     0 ?        S    Sep30   0:00 [kthreadd]
root       567  0.0  0.2 56784  8192 ?        Ssl  Sep30   0:00 /usr/bin/Xorg
user      1122  0.0  0.3 89124 12288 ?        Sl   Sep30   0:02 /usr/bin/pulseaudio
user      2455  0.0  0.1 15672  3456 pts/0    Ss   Sep30   0:00 /bin/bash
```

```
$ crontab -l

# No crontab for user
```

El análisis de procesos en memoria y tareas programadas revela que no se dejaron procesos maliciosos activos. El atacante entró, ejecutó su objetivo y limpió su rastro.

Transición al CSIRT: Modelo de Respuesta NIST SP 800-61

Ejecución Táctica: Respuesta Inmediata al Caso Práctico

1. Aislamiento

Desconexión inmediata del servidor comprometido de la red principal.

Bloqueo a nivel de `firewall`.

2. Triaje Forense

Recolección de imagen `.E01` mediante `FTK Imager`.

Preservación estricta de hashes `MD5/SHA1`.

3. Bloqueo de Vectores

Deshabilitación total de `FTP Anónimo`.

Cierre forzoso de sesiones SSH no autorizadas en curso.

4. Reconfiguración

Aplicación de Hardening en directorio `WordPress` y saneamiento de permisos en el `sistema de archivos`.

5. Restauración

Regreso a operaciones nominales desde `backups` verificados con nuevo esquema de parches de seguridad.

Arquitectura de Playbooks (CSIRT)

Protocolos operativos estandarizados para la mitigación de los vectores de riesgo identificados.

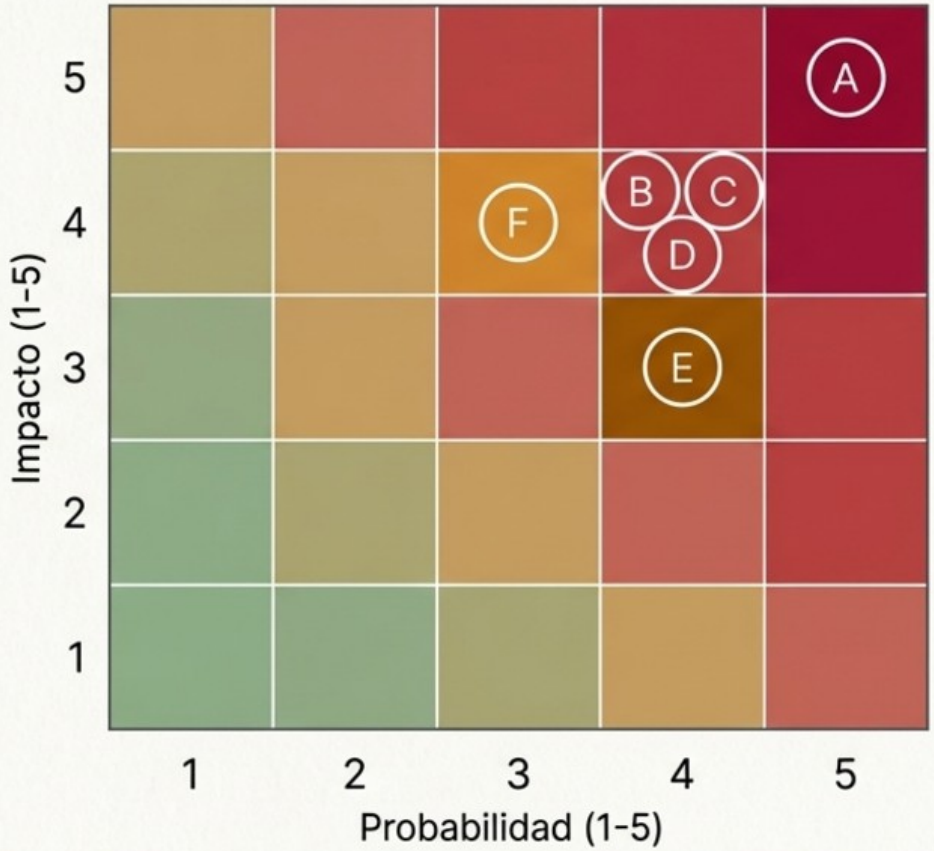
Protocolo: **Compromiso Web (WordPress)**

1. Alerta SIEM
2. Validación del incidente
3. Aislamiento del servidor
4. Captura de memoria/logs
5. Eliminación de webshells
6. Parcheo y Hardening

Protocolo: **Exfiltración de Datos (FTP/DB)**

1. Detección de tráfico saliente anómalo
2. Bloqueo de conexiones a nivel firewall
3. Identificación del host origen
4. Revocación inmediata de accesos
5. Análisis de impacto de datos
6. Notificación y cumplimiento normativo

Matriz llntriz **Cuantificada** de Riesgos (SGSI)



Leyenda de Riesgos Identificados

- A — **A (Riesgo 25):** Servidor Debian (Compromiso Remoto Crítico)
- B — **B (Riesgo 20):** Servicio FTP (Exfiltración de datos)
- C — **C (Riesgo 20):** Base de Datos MariaDB (Robo)
- D — **D (Riesgo 20):** Acceso SSH (Fuerza Bruta)
- E — **E (Riesgo 16):** Sistema Base (Falta de Parches)
- F — **F (Riesgo 15):** Credenciales (Acceso no autorizado)

Estrategia de Mitigación Estructural (El “Hardening”)

	Estado Vulnerable Histórico		Estado Fortificado Requerido
Archivos	Permisos indiscriminados 777	⇨	Principio de Mínimo Privilegio (Archivos 644, Directorios 755)
Credenciales	`wp-config.php` expuesto con clave trivial (‘123456’)	⇨	Bóveda de credenciales, cero texto plano, rotación periódica
Servicios	FTP Anónimo habilitado / SSH por contraseña	⇨	FTP deshabilitado / SSH restringido exclusivamente a cifrado por claves
Aplicación	WordPress expuesto a fuerza bruta	⇨	Autenticación Multifactor (MFA) activa, XML-RPC bloqueado

Arquitectura DLP y Protección de Datos

LUKS / AES-256. Protección física integral y cifrado de base de datos.

TLS 1.2+. Prevención de interceptación de comunicaciones.

RBAC implementado y **Autenticación Multifactor (MFA)** obligatoria.

Copias de seguridad diarias, totalmente cifradas y verificadas offline.

Alineación Normativa: ISO 27001 Declaración de Aplicabilidad (SoA)

✓	**A.9 Control de Accesos** Activado. Justificación: Protección estricta de credenciales y roles para evitar la exposición de claves maestras.
✓	**A.12 Operaciones** Activado. Justificación: Gestión rigurosa de parches y saneamiento de configuraciones seguras (eliminación definitiva de permisos 777).
✓	**A.13 Comunicaciones** Activado. Justificación: Obligatoriedad de cifrado de datos en tránsito y cierre de puertos de servicio innecesarios (FTP).
✓	**A.16 Incidentes** Activado. Justificación: Implementación formal del CSIRT, monitorización continua y Playbooks operativos estandarizados.
✓	**A.18 Cumplimiento** Activado. Justificación: Alineación garantizada con normativas de privacidad vigentes (ej. GDPR).

Métricas de Éxito: KPIs del Centro de Operaciones de Seguridad (SOC)

< 1 Hora

MTTD (Mean Time To Detect)

Identificar intrusiones en la red antes del establecimiento de persistencia.

< 4 Horas

MTTR (Mean Time To Respond)

Contención, aislamiento y erradicación rápida basada en playbooks de respuesta.

100%

Tasa de Sistemas Actualizados

Gestión de vulnerabilidades proactiva y endurecimiento de configuraciones (Hardening).

100%

Cumplimiento de Backups

Respaldos verificados, cifrados y almacenados completamente offline.

El incidente fue consecuencia de debilidades acumuladas y una higiene cibernética deficiente, no de un ataque sofisticado.

Este proyecto no solo ha resuelto un incidente, sino que ha transformado un entorno vulnerable en un sistema gestionado, monitorizado y alineado con estándares internacionales de seguridad.